

Unit 1

Layer No.	Layer Name	Main Functions	Data Unit (PDU)	Protocols / Examples
7	Application	Interface between user & network services	Data	HTTP, HTTPS, FTP, SMTP, DNS, SNMP
6	Presentation	Data encryption, compression, formatting, character encoding	Data	SSL/TLS, JPEG, MPEG, ASCII
5	Session	Session establishment, maintenance & termination	Data	NetBIOS, RPC
4	Transport	End-to-end communication, segmentation, flow control, error recovery	Segment	TCP, UDP
3	Network	Logical addressing, routing, path selection	Packet	IP, ICMP, IPSec
2	Data Link	Framing, MAC addressing, error detection, ARP	Frame	Ethernet, ARP, PPP
1	Physical	Transmission of raw bits over medium	Bits	Cables, Switch ports, Hub

Layer No.	Layer Name	Functions	Data Unit	Protocols
4	Application	Combines OSI L5, L6, L7	Data	HTTP, FTP, SMTP, DNS
3	Transport	End-to-end delivery	Segment	TCP, UDP

2	Internet	Logical addressing & routing	Packet	IP, ICMP, ARP
1	Network Access	Physical transmission & framing	Frame / Bits	Ethernet, Wi-Fi

1. Masquerade

A masquerade attack occurs when an entity pretends to be a different entity. This usually involves using stolen credentials or forging identities.

- **Explanation:** The attacker gains authentication by mimicking a legitimate user. This is often the first step in a larger sequence of attacks, as it provides the "foot in the door" needed to access restricted resources.
- **Example:** An attacker uses a captured username and password to log into a corporate VPN, appearing to the system as a remote employee.
- **Tools:** Social engineering kits, credential harvesters, IP spoofing tools.

Advantages (for the attacker):

1. Bypasses standard authentication barriers without triggering brute-force alarms.
2. Provides access to privileges assigned to the impersonated user.
3. Obfuscates the attacker's true identity, making attribution difficult.
4. Allows for lateral movement within a network.

Disadvantages (for the attacker):

1. Requires successful credential theft or identity forgery beforehand.
2. Can be detected by Behavioral Analysis (UEBA) if the attacker's actions differ from the user's norm.
3. Multi-Factor Authentication (MFA) significantly reduces the success rate.
4. Limited by the specific permissions of the account being spoofed.

2. Replay Attack

A replay attack involves capturing a valid data transmission and re-sending it later to produce a malicious effect.

- **Explanation:** The attacker does not necessarily need to know what the message says; they only need to know that sending it again will trigger a specific action, such as a login or a financial transfer.

- **Example:** Capturing the "Unlock" signal from a digital key fob and re-broadcasting it later to open a car or a secure building.
- **Tools:** Packet sniffers (Wireshark), radio frequency (RF) capture tools (HackRF One).

Advantages (for the attacker):

1. Does not require the attacker to decrypt or understand the encrypted payload.
2. Effective against systems that do not use time-stamping or one-time tokens.
3. Can be automated to repeat actions rapidly.
4. Bypasses simple password-based authentication if the session token is reused.

Disadvantages (for the attacker):

1. Completely defeated by the use of "nonces" (numbers used once) or session timeouts.
2. Requires successful interception of the original traffic.
3. Highly visible in network logs if the same sequence is seen repeatedly.
4. Sequence numbers in protocols like TCP can prevent successful re-injection.

3. Modification of Message

This attack compromises the integrity of a message by altering its contents before it reaches the intended recipient.

- **Explanation:** The attacker acts as a "Man-in-the-Middle" (MitM). They intercept the data, change it (such as changing a bank account number in a wire transfer), and forward the modified version.
- **Example:** Changing the "Pay To" field in an unencrypted web form from "Landlord" to "Attacker Account" during transit.
- **Tools:** Bettercap, Burp Suite, Ettercap.

Advantages (for the attacker):

1. Directly manipulates business logic and financial outcomes.
2. Can cause widespread misinformation or system instability.
3. Hard to detect if the receiver does not use cryptographic checksums (hashes).
4. Can be used to inject malicious scripts into otherwise safe web pages.

Disadvantages (for the attacker):

1. Requires a sophisticated "Man-in-the-Middle" position on the network.
2. Easily detected by Digital Signatures or Hash Message Authentication Codes (HMAC).
3. Encryption (like TLS/HTTPS) makes reading and modifying the content extremely difficult.
4. Connection drops or delays caused by the interception can alert the users.

4. Denial of Service (DoS)

A DoS attack aims to make a service or resource unavailable to its intended users by exhausting its capacity.

- **Explanation:** The attacker floods the target with more requests than it can handle, causing the system to slow down significantly or crash entirely.
- **Example:** Sending thousands of "SYN" packets to a web server per second, filling up its connection queue so legitimate users cannot connect.
- **Tools:** LOIC (Low Orbit Ion Cannon), Hping3, Metasploit.

Advantages (for the attacker):

1. Requires relatively low technical skill to execute basic versions.
2. Can cause massive financial and reputational damage to a business.
3. Effectively masks other malicious activities occurring simultaneously.
4. Very difficult to stop once a Distributed DoS (DDoS) from multiple sources begins.

Disadvantages (for the attacker):

1. Does not provide the attacker with access to data or systems.
2. High visibility; the attack is immediately obvious to administrators.
3. Modern cloud scrapers and CDNs (like Cloudflare) can mitigate these attacks.
4. Source IP addresses can often be traced back unless sophisticated spoofing or botnets are used.

OSI Security Architecture

1 Introduction

The **OSI Security Architecture** was defined by **International Organization for Standardization (ISO)** in standard **ISO 7498-2**.

It provides a **framework for securing communication systems** by classifying:

- ♦ Security Attacks
- ♦ Security Services
- ♦ Security Mechanisms

It does **not** define protocols.

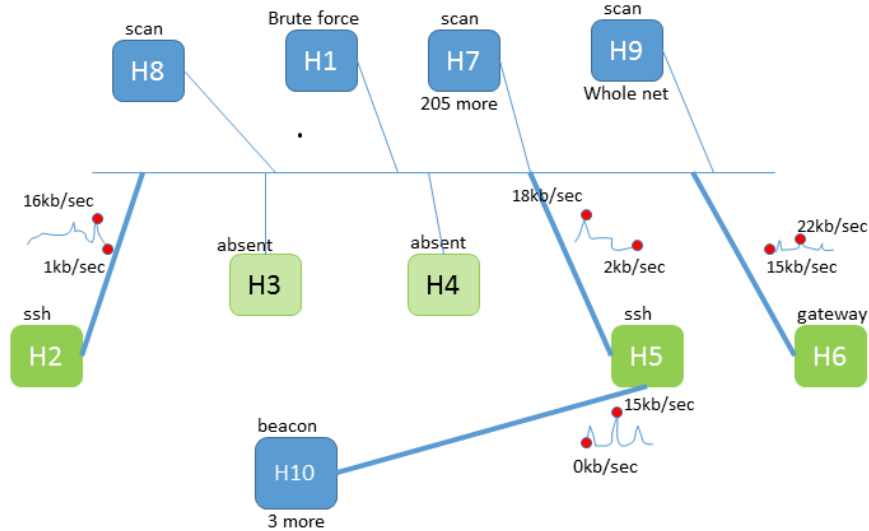
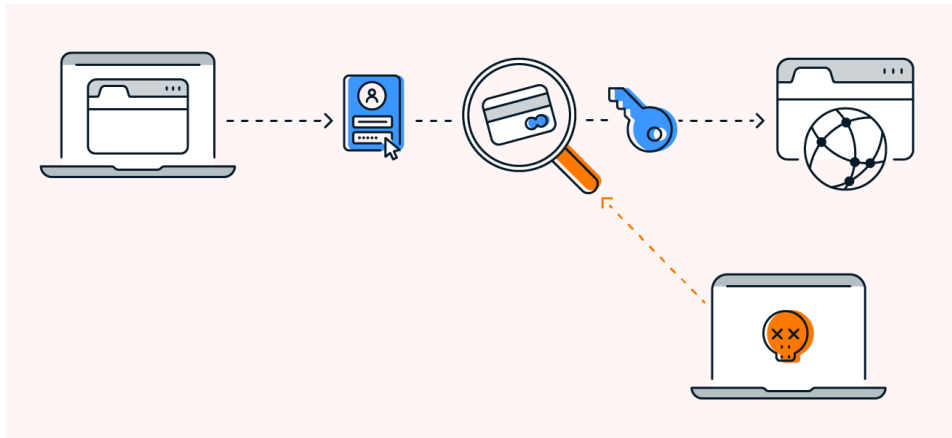
It defines **what needs to be protected** and **how protection is categorized**.

2 Security Attacks

A **security attack** is any action that compromises information security.

They are divided into two major categories:

A) Passive Attacks (No data modification)



Attacker only observes the communication.

Types:

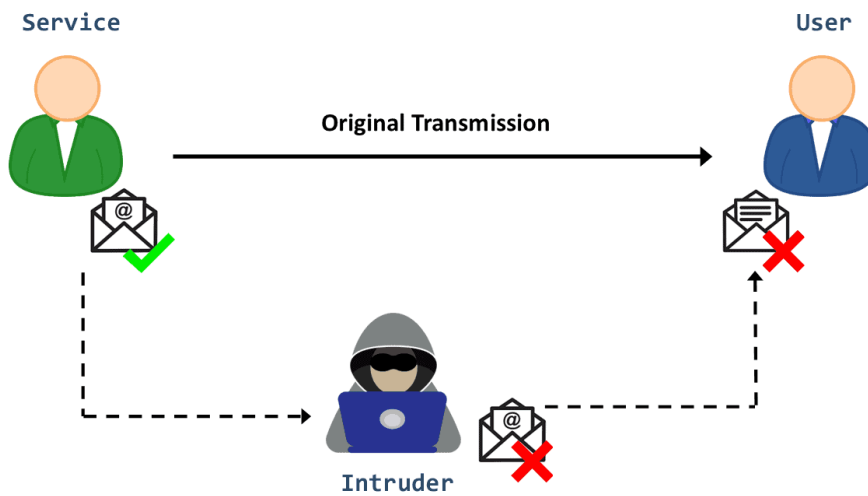
1. **Release of message contents**
 - Example: Packet sniffing passwords.
2. **Traffic analysis**

- Studying communication patterns.

⚠ Hard to detect

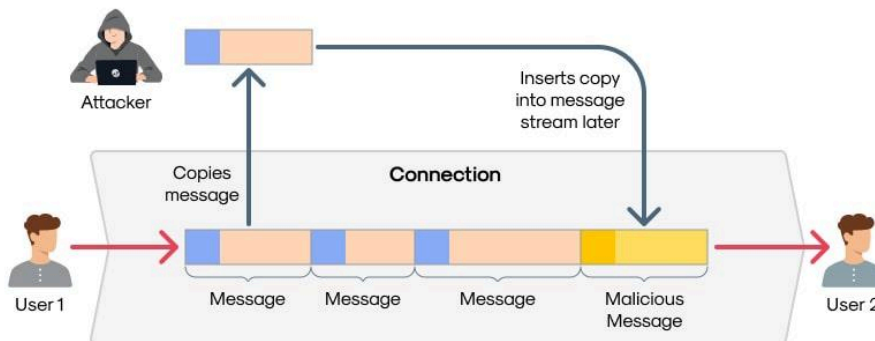
✓ Prevented using encryption

B) Active Attacks (Data modification occurs)

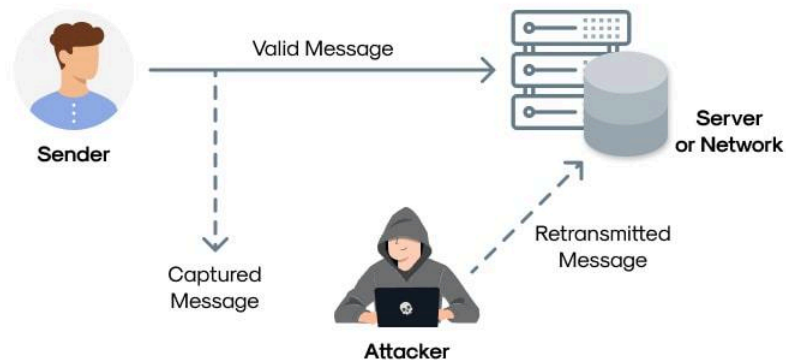


wallarm

Mechanism of Replay Attacks



The Anatomy of a Replay Attack



🚨 Attacker alters system resources or data.

Types:

1. **Masquerade** – Pretending to be someone else
2. **Replay attack** – Reusing captured data
3. **Modification of messages**
4. **Denial of Service (DoS)**

⚠️ Hard to prevent completely

✅ Must be detected and recovered

3 Security Services

Security services are provided to counter attacks.

1. Authentication

Ensures identity verification.

- Peer entity authentication
- Data origin authentication

Example: Login with digital certificate.

2. Access Control

Prevents unauthorized resource use.

Example: Role-based permissions in a server.

3. Data Confidentiality

Protects data from unauthorized disclosure.

Example: Encryption (AES, TLS).

4. Data Integrity

Ensures data is not altered.

Example: Hashing (SHA-256).

5. Non-Repudiation

Prevents denial of actions.

Example: Digital signatures.

6. Availability

Ensures systems remain accessible.

Example: DDoS protection.

4 Security Mechanisms

These are techniques used to implement services.

They are divided into:

A) Specific Security Mechanisms

- Encryption
- Digital signatures
- Access control mechanisms
- Data integrity mechanisms
- Authentication exchange

- Traffic padding
- Routing control
- Notarization

B) Pervasive Security Mechanisms

- Trusted functionality
- Security labels
- Event detection
- Security audit trail
- Security recovery

MAC Flooding Attack

MAC Flooding is a type of attack targeting network switches to compromise the security of a Local Area Network (LAN).

1. What is MAC Flooding?

Network switches maintain a **MAC Address Table** (or CAM table) that maps physical ports to the MAC addresses of connected devices. Because this table has limited memory, an attacker can overflow it with fake entries, forcing the switch into "fail-open" mode, where it acts like a hub and broadcasts all traffic to every port.

2. Sequence of Actions

1. **Interception & Generation:** The attacker uses a tool (like `macof`) to generate thousands of random MAC addresses.
2. **Flooding the Switch:** The attacker sends thousands of Ethernet frames with these fake source MAC addresses to the switch's port.
3. **Table Exhaustion:** The switch's CAM table reaches its maximum capacity and begins overwriting legitimate entries with fake ones.
4. **Fail-Open State:** Once the table is full, the switch can no longer "learn" where devices are. It defaults to broadcasting all incoming traffic to **all ports**.
5. **Sniffing:** The attacker, now receiving traffic meant for other users, uses a packet sniffer (like Wireshark) to capture sensitive data from the entire network.

Compare the ISO/OSI Model with the TCP/IP Model

1 Introduction

The **OSI model** was developed by the **International Organization for Standardization (ISO)** as a conceptual framework to standardize network communication.

The **TCP/IP model** was developed by the **Defense Advanced Research Projects Agency (DARPA)** to support the ARPANET and forms the basis of the modern Internet.

Both models describe how data moves from one device to another over a network, but they differ in structure and implementation approach.

2 Number of Layers Comparison

OSI Model	TCP/IP Model
7 Layers	4 Layers
Conceptual model	Practical implementation model
Strict layer separation	Loosely defined layers

3 OSI Layers

1. Physical
2. Data Link
3. Network
4. Transport
5. Session

6. Presentation

7. Application

4 TCP/IP Layers

1. Network Access (Link)

2. Internet

3. Transport

4. Application

5 Layer Mapping

OSI Layer	Function	TCP/IP Equivalent
Application	User interface services	Application
Presentation	Data formatting, encryption	Application
Session	Session management	Application
Transport	End-to-end delivery	Transport
Network	Logical addressing & routing	Internet
Data Link	Framing, MAC addressing	Network Access
Physical	Transmission of bits	Network Access

Explanation of Mapping

1. OSI Application, Presentation & Session → TCP/IP Application Layer

TCP/IP combines all three into a single Application layer.

Examples: HTTP, FTP, SMTP.

2. OSI Transport → TCP/IP Transport

Both handle:

- End-to-end communication
- Error control
- Flow control

Protocols: TCP, UDP

3. OSI Network → TCP/IP Internet Layer

Responsible for:

- Logical addressing
- Routing

Protocol example: IP

4. OSI Data Link + Physical → TCP/IP Network Access

Handles:

- MAC addressing
- Framing
- Physical transmission

6 Similarities Between OSI and TCP/IP

1. Both are layered models
2. Both have transport and network layers
3. Both support packet-switched communication
4. Both separate services, interfaces, and protocols
5. Both aim to standardize communication

7 Differences Between OSI and TCP/IP

Feature	OSI	TCP/IP
Developed by	ISO	DARPA
Layers	7	4
Design approach	Model first, protocol later	Protocol first, model later

Layer separation	Strict	Flexible
Session & Presentation	Separate layers	Combined
Real-world usage	Mostly reference	Widely implemented

8 Practical Example

When you open a website:

- OSI Model would process data through 7 layers
- TCP/IP model processes through 4 layers

Even though internally structured differently, the final communication outcome is the same.

9 Advantages Comparison

OSI:

- Clear conceptual understanding
- Easier troubleshooting by layer

TCP/IP:

- Practical & scalable
- Internet standard
- Simpler structure

Discuss the Importance of Switch in the Perspective of Network Forensics

1. Introduction

A switch is a Layer 2 networking device that forwards frames based on MAC addresses. In network forensics, switches play a critical role because they control how traffic flows within a network and store valuable artifacts useful during investigations.

Unlike hubs (which broadcast traffic), switches selectively forward data, which directly impacts evidence collection.

2. Importance of Switch in Network Forensics

1. Traffic Control and Segmentation

Switches divide a network into smaller segments.

Forensics relevance:

- Limits broadcast traffic
- Reduces noise during packet capture
- Helps isolate compromised systems

Example: If a malware infection spreads in VLAN 10, traffic can be analyzed separately from VLAN 20.

2. MAC Address Table (CAM Table) Evidence

Switches maintain a CAM (Content Addressable Memory) table that maps:

MAC Address → Port Number

Forensic Value:

- Identify which device was connected to which physical port
- Trace attacker's physical location inside organization

Example: If malicious traffic originates from port 5, CAM table reveals which system was connected.

3. Port Mirroring (SPAN) for Packet Capture

Switches support:

- SPAN (Switched Port Analyzer)
- Port mirroring

This allows: Copying traffic from one port to another for monitoring.

Forensic Use:

- Capture traffic using Wireshark
- Monitor suspicious host
- Analyze data exfiltration

Without port mirroring, traffic between two hosts cannot be seen easily.

4. VLAN Segmentation

Switches implement VLANs (Virtual LANs).

Forensic Importance:

- Contain lateral movement
- Track cross-VLAN attacks
- Identify privilege escalation attempts

Example: If attacker jumps from User VLAN to Server VLAN, switch logs can help trace the path.

5. Log Generation

Managed switches generate logs for:

- Port status changes
- MAC address changes
- Authentication events
- STP events

Forensic Relevance:

- Detect rogue devices
- Identify MAC spoofing
- Detect unauthorized physical access

6. ARP and MAC Spoofing Detection

Attackers may perform:

- ARP poisoning
- MAC flooding attacks

Switch forensic relevance:

- Detect abnormal MAC table overflow
- Identify suspicious MAC address changes

Example: MAC flooding may cause switch to behave like a hub, enabling sniffing attacks.

7. Time Correlation in Investigation

Switch logs help correlate:

- Timestamp of connection
- Port activity
- Link up/down events

This helps build a timeline of attack.

Example:

At 13:22 – Port 7 became active

At 13:23 – Suspicious traffic detected

Indicates possible insider or rogue device.

8. Network Access Control (NAC)

Advanced switches support:

- 802.1X authentication
- Port-based security

Forensic importance:

- Identify unauthorized systems
- Track authentication failures
- Detect bypass attempts

9. Evidence of Lateral Movement

Switch logs + traffic capture help identify:

- Internal scanning
- SMB lateral movement
- RDP propagation
- Worm activity

Switches reveal internal attack patterns that routers may not log.

10. Support for IDS/IPS Deployment

Switches enable:

- Mirroring traffic to IDS/IPS
- Integration with SIEM

This enhances:

- Intrusion detection
- Real-time forensic monitoring

3. Why Switch is More Important Than Hub in Forensics

Hub:

- Broadcasts traffic to all devices
- Easy to sniff

Switch:

- Forwards traffic selectively
- Requires port mirroring for capture
- Maintains MAC table (valuable evidence)

Thus, in modern networks, forensic analysis must rely on switch configuration and logs.

4. Conclusion

From a network forensic perspective, switches are critical because they:

- Control internal traffic flow
- Maintain MAC-to-port mappings
- Provide logging capabilities
- Support traffic mirroring
- Help detect spoofing and lateral movement

1) Hardware Firewall

Definition

A physical device placed between internal network and external network to monitor and filter traffic.

Working

- Inspects incoming/outgoing packets at network boundary
- Applies predefined rules (ACLs, policies)
- Often integrated with routers or dedicated appliances

Layer

- Mostly Layer 3 (Network) and Layer 4 (Transport)

Need

- Centralized protection for entire network
- High performance and dedicated security

Example

- Cisco ASA, Fortinet FortiGate

Advantages

- High throughput
- Protects entire network
- Less load on individual systems

Disadvantages

- Expensive
- Requires configuration expertise
- Single point of failure

Forensic Importance

- Logs of all network traffic entering/leaving
- Useful for tracing attacks, IP correlation

Key Difference

- Physical device vs software-based firewall

2) Software Firewall

Definition

Firewall installed on individual systems to control traffic per host.

Working

- Monitors incoming/outgoing traffic per application
- Applies local security policies

Layer

- Layer 4 and Layer 7 (Application-aware in modern systems)

Need

- Protect individual systems
- Useful in endpoint security

Example

- Windows Defender Firewall

Advantages

- Granular control per application
- Easy to install
- Low cost

Disadvantages

- Consumes system resources
- Can be disabled by malware
- Not centralized

Forensic Importance

- Logs application-level connections
- Helps identify compromised processes

Key Difference

- Host-level protection vs network-level protection

3) Packet-Filter Firewall

Definition

Basic firewall that filters packets based on rules like IP, port, protocol.

Working

- Checks packet headers
- Allows or blocks based on rules

Layer

- Layer 3 (IP) and Layer 4 (TCP/UDP)

Need

- Fast and simple traffic filtering

Example

- Router ACLs

Advantages

- Fast
- Low overhead
- Simple implementation

Disadvantages

- No payload inspection
- Cannot detect attacks inside packets
- Stateless

Forensic Importance

- Limited logs (only headers)
- Useful for traffic pattern analysis

Key Difference

- Stateless filtering vs deeper inspection firewalls

4) Proxy Firewall (Application-Level Gateway)

Definition

Firewall that acts as an intermediary between client and server.

Working

- Client connects to proxy
- Proxy connects to server
- Inspects full request and response

Layer

- Layer 7 (Application Layer)

Need

- Deep inspection of application data
- Hide internal network

Example

- Squid Proxy

Advantages

- High security
- Content filtering
- Hides internal IP

Disadvantages

- Slower (extra processing)
- Complex setup

Forensic Importance

- Full request/response logs
- Useful for user activity tracking

Key Difference

- Acts as middleman vs direct connection

5) Circuit-Level Gateway

Definition

Firewall that monitors TCP handshakes and session validity.

Working

- Verifies session establishment (TCP handshake)
- Does not inspect payload

Layer

- Layer 5 (Session Layer)

Need

- Ensure valid connections without heavy inspection

Example

- SOCKS proxy

Advantages

- Faster than proxy firewall
- Hides internal network

Disadvantages

- No content inspection
- Limited security

Forensic Importance

- Tracks session creation
- Useful for identifying unauthorized connections

Key Difference

- Checks session validity, not content

6) Stateful Packet Inspection (SPI)

Definition

Firewall that tracks state of active connections.

Working

- Maintains state table
- Allows packets only if part of valid session

Layer

- Layer 3 & Layer 4

Need

- Prevent spoofing and unauthorized packets

Example

- Most modern routers/firewalls

Advantages

- More secure than packet filtering
- Tracks sessions
- Efficient

Disadvantages

- More memory usage
- Still limited payload inspection

Forensic Importance

- Session logs (who connected to whom)
- Helps reconstruct attack flow

Key Difference

- Stateful vs stateless filtering

7) Next-Generation Firewall (NGFW)

Definition

Advanced firewall combining multiple security features.

Working

- Deep packet inspection (DPI)
- Application awareness
- Intrusion detection/prevention
- SSL inspection

Layer

- Layer 3 to Layer 7

Need

- Protection against modern threats (malware, APTs)

Example

- Palo Alto Networks, Check Point

Advantages

- Comprehensive security
- Application-level control
- Integrated IPS/IDS

Disadvantages

- Expensive
- Complex configuration
- Performance overhead

Forensic Importance

- Detailed logs (user, app, payload)
- Threat intelligence integration
- Useful in advanced investigations

Key Difference

- Combines multiple firewall + IDS + IPS features

Quick Comparison (Exam Revision)

Type	Layer	Inspection Level	Speed	Security
Packet Filter	L3-L4	Low	High	Low
Circuit Gateway	L5	Medium	High	Medium
Proxy Firewall	L7	High	Low	High
SPI	L3-L4	Medium-High	Medium	High
NGFW	L3-L7	Very High	Medium	Very High

Unit 2

Nmap Flag	Scan Type	Packet Sent by Nmap	Expected Target Response	What Wireshark Shows	Key Exam Point
-sS	TCP SYN Scan (Half-open scan)	Sends TCP SYN packet to target port	Open port → SYN + ACK Closed port → RST	SYN → SYN/ACK → RST sequence visible	Called Stealth Scan because connection is not fully established
-sT	TCP Connect Scan	Sends SYN , completes full TCP handshake	Open port → SYN/ACK → ACK Closed port → RST	Full 3-way handshake (SYN, SYN-ACK, ACK) visible	Uses OS connect() system call , easier to detect
-sU	UDP Scan	Sends UDP packet to target port	Closed port → ICMP Port Unreachable Open port → No response / UDP reply	UDP packet followed by ICMP Type 3 Code 3	Slow scan because UDP responses are inconsistent
-sA	TCP ACK Scan	Sends TCP ACK packet	Filtered port → No response Unfiltered port → RST	ACK packet sent, RST reply seen	Used to map firewall rules , not to detect open ports
-Pn	No Ping Scan	Skips host discovery and directly scans ports	Target may respond with normal port responses	Only scan packets , no ICMP echo request before scan	Used when ICMP is blocked by firewall
-sn	Ping Scan (Host Discovery)	Sends ICMP Echo Request, ARP, or TCP ping	Active host → ICMP Echo Reply or ARP reply	ICMP Echo Request → Echo Reply visible	Used to identify live hosts only , no port scanning
-n	No DNS Resolution	No DNS query packets sent	Target IP directly scanned	Only IP addresses , no DNS packets in capture	Makes scan faster and stealthier
-PR	ARP Ping Scan	Sends ARP Request to local network	Active host → ARP Reply	ARP Request → ARP Reply frames visible	Works only in local network (LAN)

Nmap Flag	Scan / Feature	Packet Sent by Nmap	Target Response	What Wireshark Shows	Key Exam Point
-p	Port specification	Normal scan packets sent only to specified ports	Depends on scan type	Packets only to selected ports (e.g., 80,443)	Used to limit scan to specific ports
-sP (<i>old syntax, now -sn</i>)	Ping scan / Host discovery	ICMP Echo Request, ARP request, or TCP ping	Active host → ICMP Echo Reply / ARP Reply	ICMP request → reply visible	Used to find live hosts without port scanning
-sX	Xmas Scan	TCP packet with FIN + PSH + URG flags set	Closed → RST Open → No response	Packet with unusual flags FIN+PSH+URG	Called Xmas scan because flags "light up"
-nS	NULL Scan	TCP packet with no flags set	Closed → RST Open → No response	TCP packet with all flags = 0	Used to bypass some firewall rules
-sF	FIN Scan	TCP packet with FIN flag	Closed → RST Open → No response	TCP packet with FIN flag only	Stealth scan, avoids full handshake
-O	OS Detection	Sends multiple crafted TCP, ICMP and UDP probes	OS replies differently depending on TCP/IP stack	Various probe packets visible	Used to identify operating system
-A	Aggressive Scan	Combination of OS detection, version detection, traceroute, scripts, ports	Multiple protocol responses	Mixed packets: TCP, ICMP, version probes	Enables OS detection + service detection + traceroute

1. Open

An **Open** port means an application is actively listening for connections. If you send a request, the port says "Yes, I'm here, let's talk!"

- **Security View:** This is a potential entry point for an attacker if the application running on it has a vulnerability.
- **Analogy:** You knock on the door, and someone opens it immediately.

2. Closed

A **Closed** port is accessible (not blocked by a firewall), but there is **no application** currently listening on it. It actively sends back a "Reset" (RST) packet to tell you it's shut.

- **Security View:** It confirms the host is "up" (alive), but this specific service isn't running.
- **Analogy:** You knock on the door, and a voice from inside shouts, "Nobody lives here!"

3. Filtered

The scanner cannot determine if the port is open or closed because a **firewall, filter, or router** is blocking the probes. The packets are usually dropped without any response.

- **Security View:** This tells the scanner that a security device is in the way. It's the most common "defensive" status.
- **Analogy:** You knock on the door, but the house is surrounded by a thick stone wall. You can't even tell if there's a door there, let alone if someone is inside.

4. Unfiltered

This status is unique to specific types of scans (like **ACK scans**). It means the port is accessible, but the scanner **cannot tell** if it is open or closed.

- **Security View:** This is used to map out firewall rules. It proves that your packets are getting through the firewall, but the service state remains a mystery.
- **Analogy:** You reach the door through the stone wall, but the door is made of solid steel with no handle. You're there, but you can't tell what's happening inside.

5. Open | Filtered

The scanner places a port in this category when it receives **no response at all** (which could mean it's filtered) but the type of scan used (like UDP) often gets no response even when the port *is* open.

- **Security View:** The scanner is essentially saying, "It's either open and quiet, or a firewall is eating my packets. I'm not sure which."
- **Analogy:** You leave a note under the door. Since you don't get a letter back, you don't know if they read it or if a guard threw it away.

6. Closed | Filtered

This appears in specific scans (like **IP ID Idle scans**). It means the scanner is unable to determine whether the port is closed or if it is being blocked by a filter.

- **Security View:** Similar to Open/Filtered, but specifically for states where the "Closed" signal is also missing.
- **Analogy:** You try to look through a window, but it's so dark and foggy you can't tell if the room is empty or if there's a curtain in the way.

Comparison Table for Quick Reference

Status	Response Received	What it Means
Open	SYN/ACK (TCP)	Application is running; ready to connect.
Closed	RST (TCP)	Host is up, but no service is on this port.
Filtered	None (or ICMP Error)	A firewall is blocking the communication.
Unfiltered	ACK (TCP)	Firewall allows the packet, state is unknown.

1. **--osscan-guess** (Aggressive Guessing)

Syntax: `nmap -O -p- --osscan-guess <target>`

When Nmap performs OS detection (`-O`), it compares the responses against a database of thousands of known OS "fingerprints." If it doesn't find a perfect match, it normally tells you it's unsure.

- **What it does:** This flag forces Nmap to try harder. If it can't find an exact match, it looks for the **closest possible fingerprints** and provides a percentage of how likely each guess is.
- **Why use `-p-`?** The `-p-` scans all 65,535 ports. Nmap's OS detection is much more accurate if it can find at least one open and one closed TCP port to test against.
- **Use Case:** Use this when you are scanning a rare device (like an IoT camera or an old industrial controller) that isn't explicitly in the Nmap database.

2. **--osscan-limit** (Efficient Scanning)

Syntax: `nmap -O --osscan-limit <target>`

OS detection can be a "noisy" and time-consuming process. It requires Nmap to find at least one open and one closed port to be effective.

- **What it does:** This tells Nmap: "**Only attempt OS detection if the conditions are right.**" If Nmap doesn't find at least one open and one closed TCP port on the target, it will skip the OS detection entirely for that host.
- **The Benefit:** It saves a significant amount of time, especially when you are scanning a large range of IP addresses (a subnet) where many hosts might be heavily firewalled or mostly "dead."
- **Use Case:** Use this during large-scale network discovery when you want to gather OS info quickly without wasting resources on "Filtered" or "Closed" hosts that won't yield a good fingerprint anyway.

1. External Information Gathering (Non-Technical Methods)

These methods focus on the human and physical elements of security rather than just software.

- **Dumpster Diving:** The act of retrieving discarded information from physical or digital trash to find sensitive data like passwords, network configs, or PII.
 - An attacker finds a discarded sticky note with a system password or an old hard drive that wasn't properly wiped.
 - **Countermeasure:** Implement strict shredding policies and use digital "wiping" software.
- **War Driving:** Searching for Wi-Fi networks by driving around in a vehicle with a laptop or specialized hardware to map out vulnerable access points.
 - **Exam Example:** An attacker uses a tool like **Kismet** to find a business with an old, weak WEP encryption and gains access to their internal network from the parking lot.
 - **Countermeasure:** Use WPA3 encryption and disable SSID broadcasting.

2. Domain and Network Ownership (WHOIS & RIRs)

Understanding who owns a digital asset is a critical step in the "Reconnaissance" phase.

- **WHOIS:** A public database providing ownership details, including the registrant's name, contact info, and name servers.
- **Regional Internet Registries (RIRs):** Organizations that manage the allocation of IP addresses and Autonomous System Numbers (ASNs) globally.
Key RIRs to remember for exams:

RIR	Region Covered	Website
ARIN	North America	www.arin.net
RIPE NCC	Europe, Middle East, Central Asia	www.ripe.net
APNIC	Asia-Pacific	www.apnic.net
LACNIC	Latin America, Caribbean	www.lacnic.net
AFRINIC	Africa	www.afrinic.net

3. Routing Device Enumeration

This involves identifying the specific hardware (routers and switches) that direct traffic on a network.

- **SNMP Enumeration:** Exploiting the **Simple Network Management Protocol** to gather router models, ARP caches, and routing tables. Tools: Snmpwalk, SNMPCheck, SolarWinds SNMP Scanner
- **BGP Enumeration:** Querying the **Border Gateway Protocol** to learn about Autonomous Systems (AS) and IP prefixes. Tools: bgp.he.net (Hurricane Electric's BGP Toolkit), bgpview.io
- **Countermeasure:** Always change default "community strings" (like "public" or "private") and use **SNMPv3** for encryption.

4. Exploitation Techniques

Once information is gathered, the penetration tester attempts to gain access.

- **Password Cracking:** Recovering plaintext passwords from hashes using **Brute-Force** (trying every combination) or **Dictionary Attacks** (using lists of common words).
- **Sniffing:** Capturing live network traffic to extract unencrypted credentials.
 - **Tool Tip:** Use **Wireshark** for GUI-based analysis or **Tcpdump** for command-line work.
- **Credential Extraction:** Using tools like **Mimikatz** to pull passwords directly from a computer's memory.

5. Essential Tool Comparison (Exam Table)

Expect questions asking you to match a tool to its specific purpose.

Tool Category	Popular Tools	Core Purpose
Application Assessment	Burp Suite, OWASP ZAP, SQLmap	Testing web apps for SQL Injection or XSS.

System Assessment	Nessus , OpenVAS, Nmap	Scanning OS and networks for outdated software.
Exploitation	Metasploit , ExploitDB, BeEF	Launching payloads to prove a vulnerability exists.
Post-Exploitation	Empire, Mimikatz	Maintaining access and moving laterally through a network.

Countermeasures Against Routing Device Enumeration

1. Disable Unnecessary Management Protocols

Turn off services that reveal device information such as:

- **Telnet**
- **HTTP**
- **SNMP (if not required)**

Attackers often enumerate routers through exposed management services.

2. Use Secure Management Protocols

Replace insecure protocols with encrypted ones.

Examples:

- Use **SSH instead of Telnet**
- Use **HTTPS instead of HTTP**

This prevents attackers from capturing credentials and device information.

3. Restrict Management Access Using ACLs

Configure **Access Control Lists (ACLs)** so only trusted IP addresses can access routers.

Example: Allow management access only from **network administrator machines**.

This prevents external enumeration attempts.

4. Disable SNMP or Secure It Properly

SNMP is a major source of router information leakage.

Countermeasures:

- Disable SNMP if unnecessary
- Use **SNMPv3 with authentication and encryption**
- Change default community strings like **public** and **private**.

5. Disable CDP and LLDP on Untrusted Interfaces

Protocols like:

- Cisco Discovery Protocol (CDP)
- Link Layer Discovery Protocol (LLDP)

broadcast network topology information.

Disable them on **external or public-facing interfaces**.

6. Implement Network Segmentation

Divide the network into **separate VLANs or subnets**.

Benefits:

- Limits visibility of routing devices
- Prevents attackers in one segment from discovering the entire network topology.

7. Use Firewall Rules to Block Enumeration Traffic

Configure firewalls to block scanning activities such as:

- ICMP scans
- TCP SYN scans
- UDP scans

This reduces the ability of attackers to identify routing devices.

8. Disable ICMP Responses Where Possible

Attackers use **ICMP echo requests (ping)** to identify routers and active devices. Blocking unnecessary ICMP responses reduces network mapping attempts.

9. Implement Intrusion Detection and Prevention Systems (IDS/IPS)

IDS/IPS can detect patterns of enumeration such as:

- Port scanning
- Network mapping attempts
- Routing protocol probing

Alerts allow administrators to respond quickly.

10. Use Authentication for Routing Protocols

Routing protocols like:

- OSPF
- BGP
- EIGRP

should use **authentication mechanisms** to prevent attackers from interacting with them.

Example: OSPF message digest authentication.

11. Hide Network Topology Information

Avoid exposing routing details through:

- Banner messages
- Error responses
- Diagnostic outputs

Attackers often gather network structure information from these sources.

12. Disable Unused Interfaces and Services

Unused interfaces on routers can expose unnecessary entry points.

Actions:

- Shut down unused ports
- Disable unused routing protocols.

13. Use Strong Device Hardening

Hardening reduces the risk of information disclosure. Apply security configurations such as:

- Strong passwords
- Role-based access control (RBAC)

- Limited administrative privileges.

14. Monitor Logs for Enumeration Attempts

Log analysis helps detect reconnaissance activities early. Enable logging for:

- Failed login attempts
- Port scans
- Routing protocol anomalies

15. Regular Security Audits and Network Scanning

Conduct periodic internal assessments using tools like:

- vulnerability scanners
- configuration audits

This helps identify misconfigurations that may expose routing devices.

Aspect	ICANN	RIR (Regional Internet Registry)
Full Form	Internet Corporation for Assigned Names and Numbers	Regional Internet Registry
Type	Global non-profit governing organization	Regional IP address management organizations
Main Role	Coordinates the global Internet naming and numbering system	Distributes and manages IP address blocks in specific geographic regions
Scope	Global (worldwide)	Regional (specific continents/regions)
Key Responsibility	Manages domain names, DNS root servers, and IP allocation policies	Allocates IP addresses (IPv4 & IPv6) to ISPs and organizations
Relationship	Oversees the entire Internet addressing system	Works under ICANN's allocation structure
Focus Area	Internet governance and coordination	Internet IP address distribution and registry management
What They Control	Top-level domains like .com, .org, .net and DNS root zone	Blocks of IP addresses for networks in their region

Allocation Level	Allocates large IP blocks to RIRs	Allocates IP addresses to ISPs, enterprises, and organizations
DNS Role	Responsible for DNS root management	No DNS control
Policy Development	Global policies for domain names and numbering resources	Regional policies for IP address usage and allocation
Examples	ICANN itself manages global coordination	ARIN, RIPE NCC, APNIC, AFRINIC, LACNIC
Users Served	Registrars, registries, governments, global internet community	ISPs, network operators, enterprises
Security Role	Ensures stability of global Internet infrastructure	Maintains accurate IP address registry databases
Headquarters	Los Angeles, USA	Different locations depending on region

ICANN



IANA



RIRs



ISPs



Organizations / Users

ICANN manages the global Internet naming and numbering system, while RIRs are regional organizations responsible for allocating IP addresses to networks within specific geographic regions.

In **Nmap**, two commonly asked topics in exams are:

1. **Types of Nmap Scripts (NSE – Nmap Scripting Engine)**
2. **Timing Templates (T0–T5)** – you mentioned **T1–T5**, which control scanning speed.

I'll explain them in a **clear, exam-friendly format** with **tables + key points** so it's easy to remember and write.

1. Types of Nmap Scripts (NSE Script Categories)

Nmap provides many scripts grouped into **categories**. These scripts automate tasks like vulnerability detection, information gathering, and brute force attacks.

Script Type	Purpose	What It Does	Example Use
safe	Non-intrusive scripts	Collects information without harming the system	Checking service information
default	Scripts run automatically with basic scans	Runs when using <code>-sC</code> or default script option	Detecting service banners
discovery	Information gathering	Finds hosts, services, DNS records	Network mapping
version	Service version detection	Identifies software versions running on ports	Apache version detection
auth	Authentication bypass testing	Checks authentication mechanisms	Login configuration checks
brute	Brute force attacks	Attempts password guessing	FTP/SSH password brute forcing
vuln	Vulnerability detection	Detects known vulnerabilities in services	Checking for Heartbleed
exploit	Exploitation scripts	Attempts to exploit vulnerabilities	Testing exploitability
dos	Denial of Service testing	Attempts to crash services	Stress testing servers
malware	Malware detection	Identifies malware-infected hosts	Botnet detection
intrusive	Aggressive scanning scripts	May disrupt services	Deep vulnerability analysis
external	Uses external resources	Queries external databases or APIs	WHOIS or DNS queries

broadcast	Network broadcast discovery	Finds devices via broadcast packets	Discover printers or routers
------------------	-----------------------------	-------------------------------------	------------------------------

Example Command

```
nmap --script vuln 192.168.1.10
```

Explanation

- Runs all **vulnerability detection scripts**
- Checks if the target system has **known security flaws**

2. Nmap Timing Templates (T0–T5)

Timing templates control **how fast or stealthy the scan runs**.

The syntax: `nmap -T<0-5> target`

Example: `nmap -T4 192.168.1.1`

Nmap Timing Templates Explained

Timing Level	Name	Speed	Packet Behavior	Use Case
T0	Paranoid	Extremely slow	Sends packets with long delays	IDS evasion
T1	Sneaky	Very slow	Few packets per minute	Avoid detection
T2	Polite	Slow	Reduces network load	Scanning fragile networks
T3	Normal	Default speed	Balanced scanning	Standard scanning
T4	Aggressive	Fast	Sends packets quickly	Local networks
T5	Insane	Very fast	Minimal delay between packets	High-speed networks

Detailed Behavior of T1–T5

Timing	Behavior	Packet Delay	Risk
T1 (Sneaky)	Sends packets slowly to avoid IDS detection	~15 seconds delay	Very low detection
T2 (Polite)	Reduces bandwidth usage	Moderate delay	Low network impact
T3 (Normal)	Default scanning speed	Balanced timing	Moderate detection
T4 (Aggressive)	Faster scanning using shorter timeouts	Small delay	Detectable but efficient
T5 (Insane)	Maximum speed scanning	Almost no delay	High packet loss risk

How Wireshark Shows Timing Templates

Timing	Wireshark Pattern
T1	Packets appear slowly with large gaps
T2	Packets appear steady but spaced
T3	Normal traffic pattern
T4	Rapid sequence of packets
T5	Burst of packets very quickly

Think of **speed scale**:

Level	Meaning
T1	Sneaky attacker
T2	Polite scanner
T3	Normal scan

T4	Aggressive scan
T5	Insane speed

Shortcut phrase: “Sneaky People Normally Attack Insanely”

S → T1

P → T2

N → T3

A → T4

I → T5

When **root/administrator privileges are available**, Nmap can **craft raw packets**.

Without root privileges, it must rely on **standard OS networking functions** (like `connect()`).

Nmap Scans With vs Without Root Privileges

Aspect	With Root Privileges	Without Root Privileges	Where It Is Observed
Packet Creation	Can create raw packets manually	Uses OS networking functions	Packet headers in Wireshark
Type of Scans Allowed	Supports advanced scans (SYN, FIN, NULL, Xmas)	Mostly limited to TCP Connect scan (-sT)	Nmap scan output
Stealth Capability	High stealth because connection is not completed	Low stealth because full connection is made	Firewall / IDS logs
TCP SYN Scan (-sS)	Available	Not available	Nmap output + Wireshark

FIN / NULL / Xmas scans	Available	Not available	Wireshark packet flags
UDP Scan (-sU)	Fully supported	Limited functionality	Network traffic capture
OS Detection (-O)	Works accurately	Limited or may fail	Nmap OS detection results
Packet Manipulation	Can modify TCP flags, TTL, sequence numbers	Cannot modify packet structure	Packet analysis tools
Speed	Faster scanning using custom packets	Slower due to OS handling	Scan timing
Detection by IDS	Harder to detect	Easier to detect	Intrusion detection systems
Connection Establishment	Often half-open connections	Full TCP handshake required	Wireshark TCP flow
Network Stack Usage	Bypasses OS network stack	Uses OS TCP/IP stack	System behavior
Accuracy	More accurate results	Sometimes inaccurate	Nmap results
Firewall Evasion	Better firewall bypass techniques	Limited evasion	Firewall logs

Example Scan	<code>nmap -sS target</code>	<code>nmap -sT target</code>	Terminal output
--------------	------------------------------	------------------------------	-----------------

How It Appears in Wireshark

Scenario	Wireshark Observation
Root SYN Scan	SYN packet followed by RST after SYN-ACK
Non-root Connect Scan	Full TCP handshake visible
Advanced scans	Unusual TCP flags (FIN, NULL, Xmas)
Non-root scans	Normal TCP connection packets

Unit 3

No.	Hashing	Encryption
1	Converts data into a fixed-length hash value	Converts data into ciphertext
2	One-way process	Two-way process
3	Original data cannot be recovered from hash	Original data can be recovered using a key
4	Used mainly for data integrity verification	Used mainly for data confidentiality
5	Does not require a key	Requires encryption and decryption keys
6	Even a small change in input produces a completely different hash	Small changes modify ciphertext but structure still reversible
7	Output length is fixed (e.g., 256 bits in SHA-256)	Output length depends on input size and algorithm
8	Common algorithms: MD5, SHA-1, SHA-256, SHA-3	Common algorithms: AES, DES, RSA, Blowfish
9	Used for password storage	Used for secure communication
10	Used in digital signatures and file verification	Used in secure data transmission
11	Hash values are called digest or checksum	Encrypted output is called ciphertext
12	Hashing is generally faster computationally	Encryption is relatively slower
13	Used in blockchain and data fingerprinting	Used in VPNs, HTTPS, encrypted storage
14	Vulnerable to collision attacks	Vulnerable to key attacks (brute force, cryptanalysis)
15	Example: storing password as SHA-256 hash	Example: encrypting message using AES key

No.	Symmetric Encryption	Asymmetric Encryption
1	Uses one single key for both encryption and decryption	Uses two different keys
2	Same key is shared between sender and receiver	Uses public key and private key pair
3	Public key is not involved	Public key can be shared openly
4	Private key concept does not exist	Private key must remain secret
5	Encryption and decryption use the same key	Encryption and decryption use different keys
6	Faster and computationally efficient	Slower due to complex mathematical operations
7	Suitable for large data encryption	Usually used for small data or key exchange
8	Key distribution is difficult and risky	Key distribution is easier because public key is shared
9	Requires secure channel to share the key	Does not require a secure channel for public key
10	Security depends on keeping the shared key secret	Security depends on protecting the private key
11	Mostly used for bulk data encryption	Mostly used for authentication and secure key exchange
12	Common algorithms: AES, DES, 3DES, Blowfish	Common algorithms: RSA, ECC, Diffie–Hellman
13	Used in disk encryption and file encryption	Used in digital signatures and certificates
14	Used in VPN tunnels and database encryption	Used in SSL/TLS handshakes and email encryption
15	Example: encrypting a file with AES key	Example: encrypting a message using receiver's public key

1. Fixed-Length Digest

No matter if you input a single word, a 500-page novel, or a high-definition video, the hash function always produces an output (the "digest") of the **exact same length**.

- **Example:** If you use a standard SHA-256 hash, the word "Hi" and the entire *Encyclopedia Britannica* will both result in a string exactly 64 characters long.

2. Pre-image Resistance (The "One-Way" Rule)

This means you can't look at the output and figure out what the input was. It is a "one-way street."

- **The Analogy:** Think of making a fruit smoothie. If I give you a glass of purple liquid, it is nearly impossible for you to tell me exactly how many blueberries, strawberries, or grapes I used, or what they looked like before I hit "blend."
- **In Math:** If you have the result h , you can't work backward to find x .

3. Second Pre-image Resistance (The "No Swapping" Rule)

This property ensures that if you already have a specific input and its hash, an attacker cannot find a *different* input that produces that same hash.

- **The Analogy:** Imagine you have a digital "Fingerprint" for a specific \$100 check. This property ensures that a fraudster cannot take a *different* check (for \$10,000) and somehow make it produce that same fingerprint.
- **The Goal:** It prevents someone from replacing your original message with a fake one without changing the hash.

4. Collision Resistance (The "Unique Birthdays" Rule)

This is the strongest property. It means it should be impossible to find **any** two random inputs that result in the same output.

- **The Distinction:** * **Second Pre-image** is: "I give you a specific input; find me another one that matches it." (Hard)
 - **Collision Resistance** is: "Find *any* two things in the world that result in the same hash." (Even Harder)
- **The Reality:** Because there are infinite possible inputs but limited possible outputs (fixed length), collisions *do* exist. However, a good hash function makes them so mathematically rare that you could run a supercomputer for a billion years and never find one.

1. SHA-512 Algorithm Overview

The Secure Hash Algorithm (SHA-512) processes messages in 1024-bit blocks and produces a 512-bit digest through the following five steps:

- **Step 1: Append Padding Bits:** The message is padded so its length is almost a multiple of 1024. Specifically, a single '1' bit is added, followed by enough '0' bits so the length is 896 bits short of a multiple of 1024 (congruent to 896 modulo 1024).
- **Step 2: Append Length:** A 128-bit integer representing the original message's length is appended to the message, making the total length an exact multiple of 1024.
- **Step 3: Initialize Hash Buffer:** A 512-bit buffer is initialized with a set of specific 64-bit integer constants.
- **Step 4: Process Message in Blocks:** The message is processed in 1024-bit blocks. Each block goes through **80 rounds** of processing to update the 512-bit buffer.
- **Step 5: Output:** After all blocks are processed, the final state of the buffer is the resulting hash.

2. SHA-512 Round Function

Each of the 80 rounds uses complex logical operations to ensure that changing even one bit of the input changes the entire output (the "avalanche effect").

- **Logical Functions:** The round uses functions like **AND**, **NOT**, **OR**, **XOR**, and **ROTR** (Rotate Right).
- **Word Shuffling:** In each round, eight 64-bit words (labeled *a* through *h*) are shuffled. Six of these are simply rotated into new positions, while two (words *a* and *e*) are updated using substitutions based on the previous round's values, a 64-bit constant (K_t), and a word derived from the message (W_t).

3. Patterns and Types of Hashing

The presentation identifies several methods for organizing hash operations:

- **Independent Hashing:** Hashing data pieces separately.
- **Repeated Hashing:** Feeding the output of one hash back into another hash function.
- **Combined Hashing:** Hashing multiple data points together into one digest.
- **Sequential Hashing:** Hashing data in a specific chronological or ordered sequence.
- **Hierarchical Hashing:** Organizing hashes into a tree structure (often used in blockchain technology).

4. Digital Signatures

Digital signatures use **Asymmetric (Public-Key) Cryptography** to provide authentication, integrity, and non-repudiation.

- **The Signing Process:** The sender uses their **private key** to "sign" a digital document or its hash.
- **The Verification Process:** The receiver uses the sender's **public key** to verify that the signature is valid.
- **Key Difference:** In standard encryption, the receiver's keys are used to protect the message; in digital signatures, the **sender's keys** are used to prove who sent it.

Unit 4

Difference Table: WEP vs WPA vs WPA2 vs WPA3

Parameter	WEP	WPA	WPA2	WPA3
Full Form	Wired Equivalent Privacy	Wi-Fi Protected Access	Wi-Fi Protected Access 2	Wi-Fi Protected Access 3
Introduced Year	1997	2003	2004	2018
Purpose	First wireless security protocol for WLAN	Temporary improvement over WEP	Stronger and standardized wireless security	Latest generation wireless security with modern protections
Designed To Replace	—	WEP	WPA	WPA2
Security Level	Very weak	Better than WEP but still limited	Strong and widely trusted	Strongest among all four
Main Encryption Algorithm	RC4	RC4 with TKIP	AES with CCMP	AES-based stronger modern protection
Cipher Type	Stream cipher	Stream cipher + key integrity improvements	Block cipher–based protection	Advanced modern cryptographic protection
Key Length	40-bit or 104-bit secret key + 24-bit IV	256-bit key	128-bit AES-based effective security	Stronger security model, enterprise mode offers very high cryptographic strength
Initialization Vector (IV)	24-bit IV	Uses TKIP key mixing to improve key handling	Better than WEP/WPA It has GTK & PTK	More secure session-based handling
Authentication Methods	Open System, Shared Key	WPA-PSK, WPA-Enterprise	PSK, Enterprise (802.1X)	SAE, Enterprise
Authentication Strength	Weak	Moderate	Strong	Very strong

Password-Based Security	Basic shared key	Pre-shared key supported	Strong PSK support	Stronger password security than WPA2
Enterprise Support	Very limited	Yes	Yes	Yes
Uses 4-Way Handshake	No	Yes	Yes	Replaces weak dependence with stronger methods like SAE
Uses SAE (Simultaneous Authentication of Equals)	No	No	No	Yes
Protection Against Dictionary Attacks	No	Weak	Limited	Strong
Protection Against Brute Force Attacks	No	Limited	Better than WPA	Stronger than WPA2
Protection Against Replay Attacks	No	Yes, via sequence counter	Better protection	Stronger protection
Integrity Protection	CRC-32	Message Integrity Code (MIC)	CCMP integrity checking	Strong modern integrity protection
Confidentiality	Weak	Better than WEP	Strong	Very strong
Data Integrity	Weak	Improved	Strong	Stronger
Key Management	Poor	4-way handshake improves it	Strong PTK and GTK management	Improved modern secure key establishment
Session Key Handling	Weak	Better than WEP	Strong	Stronger with forward secrecy
Forward Secrecy	No	No	No	Yes + Wifi Easy connect

Individualized Data Encryption	No	No	No	Yes
Provisioning / Easy Device Setup	No	No	Traditional setup	Supports Wi-Fi Easy Connect
Compatibility with Old Hardware	High on legacy devices	Can work on old and current devices	Widely supported	May require newer hardware/software updates
Deployment Status	Obsolete	Old / transitional	Widely deployed	Newer and gradually adopted
Current Recommendation	Not recommended	Not recommended for modern use	Recommended if WPA3 unavailable	Most recommended
Layer of Operation	Data link and physical layer	WLAN security protocol	WLAN security protocol	WLAN security protocol
Best Use Case	Historical study only	Transitional legacy systems	Standard secure wireless deployment	High-security modern wireless networks
Weaknesses	Static keys, IV reuse, weak RC4, weak integrity	PSK brute force, TKIP-related weaknesses	KRACK vulnerability, handshake-related weaknesses	Fewer known practical weaknesses compared to previous versions
Known Attacks	Easy cracking, key recovery	Beck-Tews attack, PSK guessing	KRACK attack	Designed to resist many older attack styles
Resistance to Modern Attacks	Very poor	Moderate	Good but not perfect	Best among these protocols
Message Authentication	CRC-32 only	MIC	CCMP	Stronger authenticated encryption mechanisms
Broadcast / Multicast Protection	Weak	Limited	Good	Improved protection

Enterprise Cryptographic Strength	Weak	Moderate	Strong	Very strong, especially in enterprise mode
Ease of Cracking	Very easy	Easier than WPA2/WPA3	Harder	Hardest among these
Practical Status Today	Deprecated	Largely outdated	Still common	Modern preferred standard

Short Exam-Focused Comparison

Feature	WEP	WPA	WPA2	WPA3
Encryption	RC4	RC4 + TKIP	AES-CCMP	Advanced AES-based stronger protection
Authentication	Open / Shared Key	PSK / Enterprise	PSK / Enterprise	SAE / Enterprise
Security	Weak	Better	Strong	Strongest
Major Flaw	Easy to crack	TKIP and PSK weaknesses	KRACK	Needs newer support but strongest
Usage Today	Avoid	Avoid	Common	Best choice

No.	Promiscuous Mode	Monitor Mode
1	Captures all packets reaching NIC	Captures all wireless frames in the air
2	Works on both wired and wireless networks	Works only on wireless networks
3	Captures traffic within same network segment	Captures traffic from entire wireless channel

4	Requires connection to network	Does not require connection to network
5	Operates at higher level (after association)	Operates at raw frame level (before association)
6	Cannot capture packets from other networks	Can capture packets from any nearby network
7	Used mainly in Ethernet environments	Used in Wi-Fi environments
8	Captures data frames only	Captures data, control, and management frames
9	Does not capture beacon frames	Captures beacon frames (SSID info)
10	Limited visibility	Full visibility of wireless traffic
11	Cannot detect hidden SSIDs easily	Can help detect hidden SSIDs
12	Used in tools like tcpdump, Wireshark	Used in tools like airodump-ng
13	Requires standard NIC support	Requires special NIC/driver support
14	Lower risk of detection	Higher risk due to active scanning (sometimes)
15	Used for general packet analysis	Used for wireless auditing, hacking, forensics

WLAN-based attacks with their key characteristics, structured for exam use:

1. **Eavesdropping (Sniffing):** Unauthorized interception of wireless traffic using tools like packet sniffers. Common in open or weakly encrypted networks. The attacker remains passive and hard to detect.
 2. **Rogue Access Point (Evil Twin):** Attacker sets up a fake access point with the same SSID as a legitimate one. Users unknowingly connect, allowing interception of credentials and data.
 3. **Man-in-the-Middle (MITM):** Attacker positions themselves between client and access point. Traffic is intercepted, modified, or redirected without user awareness.
 4. **Denial of Service (DoS):** Flooding the network or sending deauthentication/disassociation frames to disrupt connectivity. Makes the network unavailable to legitimate users.
 5. **Deauthentication Attack:** Attackers send fake deauth frames to disconnect users from Wi-Fi. Often used to force reconnection to a rogue AP.
 6. **WEP Cracking:** Exploits weaknesses in WEP encryption using captured packets. Allows the attacker to recover encryption keys and access the network.
 7. **WPA/WPA2 Handshake Capture Attack:** Attacker captures handshake during client authentication and performs offline password cracking (dictionary/brute force).
 8. **MAC Spoofing:** Attacker changes their MAC address to impersonate a legitimate device and bypass MAC filtering.
 9. **Session Hijacking:** Attacker takes over an active session after authentication, gaining unauthorized access without needing login credentials.
 10. **Jamming Attack:** Attacker transmits radio signals to interfere with wireless communication, causing network disruption.
-

Countermeasures and best practices for WLAN security, written in an exam-ready format with explanation:

1. **Use strong encryption (WPA3/WPA2-AES)**
Avoid WEP and WPA. WPA3 provides stronger authentication and protection against brute-force attacks.
2. **Strong and complex passwords**
Use long, non-dictionary passphrases to prevent cracking of WPA/WPA2 handshakes.
3. **Disable SSID broadcasting (when needed)**
Reduces visibility of the network, though not a complete security measure.
4. **Enable MAC address filtering**
Allows only approved devices to connect, adding an extra layer of control (though spoofable).
5. **Use network segmentation (VLANs)**
Separate guest and internal networks to limit attack impact and lateral movement.
6. **Implement Intrusion Detection/Prevention Systems (WIDS/WIPS)**
Detects rogue access points, unusual traffic, and wireless attacks in real time.
7. **Regular firmware and patch updates**
Keep routers and access points updated to fix known vulnerabilities.

8. **Disable unused services and ports**
Turn off unnecessary features like remote management, WPS, etc., to reduce attack surface.
9. **Use VPN for sensitive communication**
Encrypts data end-to-end, even if the wireless network is compromised.
10. **Continuous monitoring and logging**
Analyze logs for unusual behavior such as repeated authentication failures or unknown devices.

Key security issues related to Wireless Access Points (WAPs):

1. **Weak or outdated encryption:** Use of WEP or weak WPA configurations makes it easy to crack keys and gain unauthorized access.
2. **Default credentials:** Many WAPs are deployed with default admin usernames/passwords, allowing attackers to take control of the device.
3. **Rogue access points:** Unauthorized APs installed by employees or attackers create backdoors into the network.
4. **Evil twin attacks:** Fake APs mimicking legitimate ones trick users into connecting, enabling data interception.
5. **MAC address spoofing:** Attackers bypass MAC filtering by cloning a legitimate device's MAC address.
6. **Unsecured management interfaces:** Web-based admin panels exposed over HTTP or open networks can be accessed and manipulated.
7. **Denial of Service (DoS) attacks:** Deauthentication and jamming attacks can disrupt connectivity for all users.
8. **Lack of network segmentation:** If WAP is not properly segmented, attackers gaining access can move laterally into internal systems.
9. **WPS (Wi-Fi Protected Setup) vulnerabilities:** PIN-based WPS is vulnerable to brute-force attacks, allowing quick network access.
10. **Insufficient logging and monitoring:** Without proper logs, detecting attacks like intrusion, rogue APs, or abnormal activity becomes difficult.

Unit 5

No.	Aspect	Active Network Monitoring	Passive Network Monitoring
1	Meaning	Actively sends packets or requests into the network to analyze responses.	Observes and captures existing network traffic without sending packets.
2	Network Interaction	Direct interaction with network devices.	No interaction with network devices.
3	Traffic Generation	Generates additional traffic for analysis.	Does not generate any additional traffic.
4	Detection Risk	Higher chance of being detected by attackers or systems.	Very stealthy and usually undetectable.
5	Purpose	Used for testing, scanning, and probing network behavior.	Used for monitoring and analyzing ongoing network activity.
6	Use in Network Security	Used for vulnerability scanning, penetration testing, and network mapping.	Used for threat detection, anomaly detection, and traffic monitoring.
7	Use in Digital Forensics	Helps investigators actively test systems during investigation.	Used to capture evidence without altering the system.
8	Impact on Network	Can increase network load or affect performance.	Minimal impact because it only listens to traffic.
9	Data Collection Method	Sends queries and analyzes responses from hosts.	Captures packets flowing through the network.
10	Information Gathered	Host availability, open ports, services, and vulnerabilities.	Communication patterns, packet contents, and protocols.
11	Example Tools	Nmap, Nessus, OpenVAS, Netcat	Wireshark, tcpdump, Zeek (Bro), Snort
12	Techniques Used	Port scanning, vulnerability scanning, ping sweeps, traceroute.	Packet sniffing, traffic analysis, deep packet inspection.
13	Network Visibility	Limited to responses from targeted systems.	Can monitor entire network traffic at monitoring points.
14	Forensic Integrity	May alter network state or logs during investigation.	Preserves forensic integrity because it does not modify network traffic.
15	Typical Deployment	Used during security assessments and penetration testing.	Used in continuous monitoring systems like IDS and network sensors.

For **exam answers in Digital Forensics / Network Forensics**, the **types of evidence** are usually asked as a **10-mark or 15-mark question**. Below is a **structured, exam-ready explanation with definitions and correct examples**.

Types of Evidence in Digital Forensics

Evidence refers to **information or material used to establish facts during an investigation or court proceeding**. In digital investigations, evidence can exist in **physical, digital, or testimonial form**.

The major types of evidence are:

1. Real Evidence
2. Best Evidence
3. Direct Evidence
4. Circumstantial Evidence
5. Hearsay Evidence
6. Business Records Evidence
7. Digital Evidence
8. Network-Based Digital Evidence

1. Real Evidence (Physical Evidence)

Definition

Real evidence refers to **tangible, physical objects that were directly involved in the crime**.

It represents the **actual physical items associated with the incident**.

Key Characteristics

- Physical in nature
- Can be directly examined by investigators
- Often the most convincing evidence in court
- Requires proper **chain of custody**

Examples

- The **weapon used in a crime**
- **Fingerprints** or footprints found at a crime scene
- A **USB drive containing stolen data**

- A computer or laptop used by an attacker
- A hard disk containing illegal files

Cybersecurity Example

If a hacker used a **USB drive to steal company data**, the **USB device itself becomes real evidence**.

2. Best Evidence

Best evidence refers to the **most accurate and original form of evidence available**.

According to the **Best Evidence Rule**, the **original document, recording, or data should be presented whenever possible**.

Key Characteristics

- Original source of information
- Minimizes manipulation or alteration
- Preferred in legal proceedings

Examples

- The **original email message**
- The **original log file**
- A **bit-by-bit disk image**
- The **original contract document**

Cybersecurity Example

Instead of showing a screenshot of logs, investigators present the **original server log file or forensic disk image**.

3. Direct Evidence

Direct evidence **directly proves a fact without needing inference or reasoning**. It usually comes from **witness testimony or direct observation**.

Key Characteristics

- Directly proves the incident
- No logical deduction required

- Often given by witnesses

Examples

- A witness saying: *"I saw him copying company data to a USB drive."*
- CCTV recording showing a person accessing a server
- Screen recording of a hacking activity

Cybersecurity Example

A security analyst observing a hacker executing commands in real time.

4. Circumstantial Evidence

Circumstantial evidence **does not directly prove the crime but suggests it through logical inference**. It requires **connecting multiple pieces of evidence**.

Key Characteristics

- Indirect evidence
- Requires analysis and correlation
- Common in digital investigations

Examples

- Login from a suspect's IP address
- Suspicious files found on a system
- Email metadata linking a user to an attack

Cybersecurity Example

If:

- A hacking tool is found on a suspect's laptop
- Logs show activity from that laptop

Then these combined pieces **suggest involvement in the attack**.

5. Hearsay Evidence

Hearsay is **second-hand information provided by someone who did not directly witness the event**. It is generally **not admissible in court unless supported by other evidence**.

Key Characteristics

- Based on statements of others
- Indirect testimony
- Often unreliable without verification

Examples

- “Someone told me he hacked the server.”
- “I heard the employee stole company data.”
- A message claiming someone committed a crime

Cybersecurity Example

An employee saying: *“Another colleague told me the attacker was an insider.”*

6. Business Records Evidence

Business records are **documents generated and maintained during normal business operations**.

These records are considered **reliable because organizations depend on them for daily operations**.

Key Characteristics

- Created routinely
- Maintained by organizations
- Often automatically generated

Examples

- Access logs
- Payment records
- Employment contracts
- System activity logs
- Server logs

Cybersecurity Example

A company’s **firewall logs showing unauthorized access attempts**.

7. Digital Evidence

Digital evidence refers to **information stored or transmitted in digital form that can be used in investigations**. It exists on **computers, storage devices, or digital systems**.

Key Characteristics

- Stored electronically
- Can be easily duplicated
- Requires forensic tools for analysis

Examples

- Emails
- Chat messages
- Digital documents
- Database records
- System logs

Cybersecurity Example

An **email used for phishing** or **malware downloaded onto a system**.

8. Network-Based Digital Evidence

Network-based evidence refers to **digital evidence generated through network communications**. It is usually collected from **network devices or monitoring tools**.

Key Characteristics

- Related to network traffic
- Often volatile
- Requires packet capture tools

Examples

- Packet captures (PCAP files)
- Network traffic logs
- Web browsing history
- DNS logs
- Firewall logs

Cybersecurity Example

Packet capture showing **data exfiltration to a remote server**.

Comparison Table

Evidence Type	Description	Example
Real Evidence	Physical objects related to crime	USB drive used for data theft
Best Evidence	Original form of information	Original log file
Direct Evidence	Directly proves fact	CCTV footage
Circumstantial Evidence	Indirect evidence requiring inference	Login logs
Hearsay Evidence	Second-hand statement	"He told me he hacked it"
Business Records	Organizational records	Firewall logs
Digital Evidence	Data stored electronically	Emails
Network Evidence	Evidence from network traffic	Packet capture

OSCAR Methodology in Network Forensics

OSCAR is a structured **network forensic investigation methodology** used to handle digital incidents systematically.

It ensures that evidence is **collected, preserved, analyzed, and reported properly** so that it can be **accepted in legal proceedings**.

The acronym **OSCAR** stands for:

- **O – Obtain Information**
- **S – Strategize**
- **C – Collect Evidence**
- **A – Analyze**
- **R – Report**

This model guides investigators from **incident discovery to final reporting**.

1. Obtain Information

This is the **initial stage of the investigation**, where investigators gather all available information about the incident.

The objective is to **understand the incident, environment, and scope of investigation**.

Information Collected

1. Incident Details

Investigators collect:

- Description of the incident
- Date and time of detection
- Method of discovery
- Systems affected
- Actions taken after discovery
- Persons involved

2. Environment Details

Understanding the infrastructure helps investigators locate possible evidence sources.

Important aspects include:

- Network topology
- Business model of the organization
- Organizational structure
- Legal constraints
- Communication systems
- Incident response policies

Example

If a **company server is hacked**, investigators gather:

- When the breach occurred
- Which server was affected
- Which employees had access
- Network architecture

2. Strategize

After collecting basic information, investigators **develop a plan for the investigation**.

The aim is to **determine the best approach to gather and analyze evidence**.

Important Activities

1. Identify investigation goals
2. Determine available resources
3. Identify possible evidence sources
4. Estimate value of each evidence source
5. Prioritize evidence acquisition
6. Plan investigation timeline
7. Define communication strategy

Why Strategy is Important

Without proper strategy:

- Evidence may be lost
- Systems may be disrupted
- Investigation may take longer

Example

Investigators may decide to collect:

- Firewall logs first
- Then server logs
- Then network packet captures

because **network logs may overwrite quickly**.

3. Collect Evidence

This phase involves **acquiring digital evidence from systems and networks** while maintaining forensic integrity. The process must ensure **evidence is not altered or destroyed**.

Three Important Components

1. Documentation

Investigators must record:

- Systems accessed
- Actions performed
- Tools used
- Time of collection

2. Capture

Actual acquisition of evidence such as:

- Packet captures
- System logs
- Disk images
- Memory dumps

3. Store / Transport

Evidence must be:

- Stored securely
- Protected from tampering
- Maintained with **chain of custody**

Best Practices

- Acquire evidence **as soon as possible**
- Make **cryptographic copies**
- Preserve **original evidence**
- Analyze **only the copies**
- Use reliable forensic tools

Example

Investigators capture:

- Network traffic using **Wireshark**
- Hard disk image using **FTK Imager**
- Server logs

4. Analyze

In this stage, investigators **examine the collected evidence to identify suspicious activities and reconstruct events.**

Key Analysis Activities

1. Correlation

Compare multiple data sources:

- Logs
- Network packets
- Authentication events

2. Timeline Creation

Investigators reconstruct the sequence of events:

- Login time
- File access
- Data transfer

3. Identify Events of Interest

Detect suspicious actions such as:

- Unauthorized access
- Malware execution
- Data exfiltration

4. Corroboration

Verify evidence from multiple sources to **reduce false positives**.

5. Recovery of Additional Evidence

Sometimes analysis reveals **new evidence sources**.

6. Interpretation

Investigators determine:

- How the attack happened
- Who was responsible
- What damage occurred

Example

Investigators correlate:

- Firewall logs
- VPN logs
- Authentication logs

to confirm **an attacker accessed the network using stolen credentials**.

5. Report

The final phase involves **documenting findings in a clear and structured report**. The report should be understandable by **technical and non-technical audiences**.

Important Characteristics of the Report

A good forensic report must be:

- **Clear**
- **Factual**
- **Detailed**
- **Legally defensible**

Audience of the Report

Reports may be read by:

- Judges
- Legal teams
- Managers
- HR departments
- Investigators

Contents of the Report

Typical forensic report includes:

1. Incident summary
2. Investigation methodology
3. Evidence collected
4. Analysis results
5. Timeline of events
6. Conclusion and recommendations

Example

A report might conclude:

“Unauthorized access occurred on March 12 using stolen administrator credentials. The attacker attempted data exfiltration but no confidential data was successfully transferred.”

Challenge	Description
Volatility	Network data disappears quickly
Evidence Source Identification	Difficult to locate where evidence exists

Limited Storage	Devices store small logs
High Traffic Volume	Huge amount of data generated
Encryption	Data content hidden
Privacy Issues	Legal restrictions on monitoring
Attribution Difficulty	Hard to identify attacker
Distributed Networks	Evidence spread across systems
Dynamic IP	IP addresses frequently change
Live System Impact	Collection may alter systems
Evidence Integrity	Risk of data alteration
Network Disruption	Monitoring tools affect network
Time Sync Issues	Different device timestamps
Log Format Differences	No standard logging format
Legal Admissibility	Court acceptance challenges

What is **tcpdump**?

tcpdump is a **command-line packet analyzer (sniffer)** used to:

- Capture network traffic
- Display packets in real-time
- Save packets for later analysis

It works on top of **libpcap**, which allows capturing packets directly from network interfaces.

Why is **tcpdump** important?

- Captures **Layer 2–Layer 4 traffic**
- Can be used as **digital evidence in court** due to high fidelity
- Used in:
 - Network forensics

- Incident response
- Troubleshooting
- Malware analysis

Basic Working

- It listens to a **network interface**
- Captures packets **bit-by-bit**
- Displays them in:
 - Human-readable format
 - Hexadecimal
 - ASCII (if text data)

Basic Syntax

`tcpdump [options] [filter]`

Most Important Commands

1. Select Interface

`tcpdump -i eth0`

👉 Capture packets from interface `eth0`

2. Do not resolve names

`tcpdump -n`

Shows IP addresses instead of domain names (faster)

3. Capture and save to file

`tcpdump -i eth0 -w file.pcap`

Stores packets in `.pcap` file for analysis (Wireshark etc.)

4. Read from saved file

`tcpdump -r file.pcap`

Opens previously captured packets

5. Full packet capture (important)

```
tcpdump -s 0
```

Capture **entire packet** (otherwise it may truncate data)

6. Limit file size

```
tcpdump -C 10 -w file.pcap
```

Creates new file after 10 MB

7. Rotate files

```
tcpdump -C 10 -W 5 -w file.pcap
```

Keeps only 5 files, rotates automatically

8. List interfaces

```
tcpdump -D
```

Shows all available network adapters

Filtering

Filtering is done using **BPF (Berkeley Packet Filter)**. Helps capture only relevant traffic

◆ Basic Filters

1. Capture specific host

```
tcpdump host 192.168.1.1
```

2. Capture specific port

```
tcpdump port 80
```

3. Capture TCP traffic

```
tcpdump tcp
```

4. Source & Destination

```
tcpdump src 192.168.1.1
```

```
tcpdump dst 192.168.1.1
```

5. Combine conditions

tcpdump host 192.168.1.1 and port 80

6. Exclude traffic

tcpdump not port 80

Practical Example (from your PPT)

tcpdump -nni eth0 'not (tcp and port 80)'

Capture everything **except HTTP traffic**

Target specific host and save

tcpdump -i eth0 -s 0 -w capture.pcap 'host 10.10.10.10'

Capture full packets only for that host

Advanced Filtering

Byte-level filtering

ip[9] != 1

Filter based on protocol field

Bitmask filtering

ip[0] & 0x0F > 0x05

Check header length (used in deep analysis)

Complex example (PPT-based)

ip[6] & 0x80 != 0

Detect packets with “**evil bit**” set

Important Concept: Snap Length (snaplen)

- Defines how many bytes of each packet to capture

Example: tcpdump -s 0

Capture full packet

Key Point:

- Too small → data loss
- Too large → performance issue

Real-World Use Cases

- Detect suspicious traffic
- Capture malware communication
- Investigate data exfiltration
- Analyze attacks (DoS, brute force, etc.)
- Collect **network-based digital evidence**

What is BPF?

BPF (Berkeley Packet Filter) is a filtering mechanism/language used by tools like **tcpdump** to:

- Capture only specific network packets
- Ignore unnecessary traffic
- Improve performance and analysis speed

👉 In simple words:

BPF = “smart filter for network traffic”

Why BPF is important

- Reduces huge traffic noise
- Helps in targeted investigation
- Essential in:
 - Network forensics
 - IDS/IPS (Snort, Suricata)
 - Packet analysis tools

📌 Without BPF → you capture everything (messy + slow)

Where BPF is used

- `tcpdump`
- Wireshark (capture filters)
- Snort
- Nmap

👉 It works with libpcap to filter packets at a low level.

Basic Idea

BPF checks packet fields like:

- IP address
- Port number
- Protocol (TCP, UDP, ICMP)
- Even specific bytes and bits inside packets

Structure of BPF

BPF filters are made using:

1. Type qualifiers

Define what you are filtering

- `host`
- `net`
- `port`

2. Direction qualifiers

Define traffic direction

- `src` (source)
- `dst` (destination)
- `src or dst`

3. Protocol qualifiers

Define protocol type

- `tcp`
- `udp`
- `icmp`
- `ip`

Basic Examples

1. Filter by host: `tcpdump host 192.168.1.1`

2. Filter by port: `tcpdump port 80`

3. Filter by protocol: `tcpdump tcp`

4. Source & Destination:

`tcpdump src 192.168.1.1`

`tcpdump dst 192.168.1.1`

5. Combine conditions: `tcpdump host 192.168.1.1 and port 80`

6. Multiple options: `tcpdump port 80 or port 443`

7. Exclude traffic: `tcpdump not port 80`

Logical Operators

- `and`
- `or`
- `not`

👉 Example: `tcpdump host 192.168.1.1 and not port 22`

Advanced BPF (High scoring topic)

1. Byte-level filtering

`ip[9] != 1`

- 👉 Checks specific byte in IP header
- 👉 Used for protocol-level filtering

2. Multi-byte filtering

`tcp[0:2] = 80`

- 👉 Checks first 2 bytes of TCP header

3. Bitmask filtering

`ip[0] & 0x0F > 5`

- 👉 Used to inspect specific bits inside packet
- 📌 This is called bitmasking

Real Example

`tcpdump -nni eth0 'not (tcp and port 80)'`

- 👉 Capture everything except HTTP traffic
- Works at low level (packet level)
- Very fast and efficient
- Supports:
 - Simple filters
 - Complex conditions
 - Byte/bit inspection

PYQs

IEEE 802.11

IEEE 802.11 refers to a family of standards developed by the IEEE for wireless local area networking (WLAN). It defines how devices communicate over radio waves in unlicensed frequency bands such as 2.4 GHz, 5 GHz, and 6 GHz. The protocol suite specifies both the Physical Layer (PHY) and the Medium Access Control (MAC) layer, ensuring interoperability, reliability, and security in wireless communication.

At the Physical Layer, 802.11 defines transmission techniques including DSSS (Direct Sequence Spread Spectrum), FHSS (Frequency Hopping Spread Spectrum), and OFDM (Orthogonal Frequency Division Multiplexing). Modern standards like 802.11n, 802.11ac, and 802.11ax use OFDM combined with MIMO (Multiple Input Multiple Output) to increase throughput and spectral efficiency. Channel bandwidths vary from 20 MHz to 160 MHz depending on the standard, directly impacting data rates and performance.

The MAC layer is responsible for controlling access to the shared wireless medium. It uses CSMA/CA (Carrier Sense Multiple Access with Collision Avoidance) instead of CSMA/CD used in Ethernet. Before transmitting, a device senses the channel; if idle, it waits for a random backoff period to minimize collisions. Acknowledgment (ACK) frames are used to ensure reliable delivery. Additional mechanisms like RTS/CTS (Request to Send / Clear to Send) help mitigate hidden node problems.

802.11 defines two primary network architectures. In Infrastructure mode, devices communicate through an Access Point (AP), forming a Basic Service Set (BSS). Multiple BSSs interconnected create an Extended Service Set (ESS), enabling roaming. In Ad hoc mode (IBSS), devices communicate directly without an AP, suitable for temporary networks.

Frame structure is a key part of 802.11. Frames are categorized into Management, Control, and Data frames. Management frames handle network discovery, authentication, and association (e.g., Beacon, Probe Request/Response). Control frames assist in medium access and reliability (e.g., ACK, RTS, CTS). Data frames carry actual payload. Each frame includes fields such as Frame Control, Duration, Addresses, Sequence Control, and Frame Check Sequence (FCS).

Security mechanisms evolved significantly in 802.11. Early implementations used WEP (Wired Equivalent Privacy), which was insecure due to weak key management and IV reuse. It was replaced by WPA (Wi-Fi Protected Access), introducing TKIP for dynamic keying. WPA2, based on IEEE 802.11i, uses AES-based CCMP encryption and provides strong security through the 4-way handshake mechanism for key exchange. WPA3 further enhances security with SAE (Simultaneous Authentication of Equals), protecting against dictionary attacks and improving forward secrecy.

Different amendments of 802.11 define performance enhancements. 802.11a operates in the 5 GHz band using OFDM with up to 54 Mbps. 802.11b uses DSSS in 2.4 GHz with up to 11 Mbps. 802.11g combines OFDM with 2.4 GHz, achieving 54 Mbps. 802.11n introduces MIMO and channel bonding, supporting up to 600 Mbps. 802.11ac operates in 5 GHz with wider channels

and MU-MIMO, reaching gigabit speeds. 802.11ax (Wi-Fi 6) improves efficiency using OFDMA, target wake time (TWT), and better performance in dense environments. 802.11be (Wi-Fi 7) further enhances throughput and reduces latency with multi-link operation and extremely wide channels.

Quality of Service (QoS) is addressed by 802.11e through Wi-Fi Multimedia (WMM), prioritizing traffic such as voice and video. Power management features allow devices to conserve energy by entering sleep modes and waking periodically to receive buffered data.

In summary, IEEE 802.11 protocols provide a comprehensive framework for wireless communication, covering radio transmission techniques, medium access control, network architecture, frame structure, security, and performance enhancements, making them fundamental to modern Wi-Fi networks.

4-way handshake in WPA2

The 4-way handshake in WPA2 (defined under IEEE 802.11i) is a key management process used to securely establish encryption keys between the Access Point (AP) and the client (station). It ensures that both parties share a common secret without transmitting it over the network and verifies mutual authenticity.

The process starts after successful authentication (e.g., PSK or 802.1X), where both the AP and client already possess a shared key called the Pairwise Master Key (PMK). The 4-way handshake is then used to derive a fresh session key called the Pairwise Transient Key (PTK), which is used for encrypting actual data.

Message 1: The AP sends a random number called ANonce (Authenticator Nonce) to the client. This nonce is used to ensure freshness and prevent replay attacks. At this stage, the client has not yet generated the session key.

Message 2: The client generates its own random number called SNonce (Supplicant Nonce). Using PMK, ANonce, SNonce, and MAC addresses of both devices, it derives the PTK. The client then sends SNonce along with a Message Integrity Code (MIC) back to the AP. This MIC proves that the client possesses the correct PMK without revealing it.

Message 3: The AP now also computes the PTK using PMK, ANonce, SNonce, and MAC addresses. If the MIC from Message 2 is valid, the AP confirms the client is legitimate. The AP then sends the Group Temporal Key (GTK), encrypted using PTK, along with another MIC. GTK is used for broadcast and multicast traffic.

Message 4: The client installs the PTK and GTK, verifies the MIC, and sends a final acknowledgment to the AP confirming successful key installation. At this point, secure communication begins.

Key components involved include PMK (long-term shared key), PTK (session key for unicast traffic), and GTK (key for broadcast/multicast). The handshake also provides protection against replay attacks using nonces and ensures data integrity using MIC.

Security significance: The 4-way handshake prevents key exposure, supports mutual authentication, and ensures fresh session keys for each connection. However, it is vulnerable to attacks like the KRACK attack if retransmissions are manipulated, allowing attackers to reinstall keys and replay packets.

Security advantages and limitations of the WPA2 4-way handshake (as defined in IEEE 802.11i) can be analyzed from a protocol and attack-resilience perspective.

Security Pros (8 points)

1. Mutual authentication: Both client and Access Point verify possession of the PMK, preventing unauthorized association.
2. No key transmission: The PMK is never sent over the air, reducing exposure to interception attacks.
3. Fresh session keys: PTK is derived using nonces (ANonce and SNonce), ensuring unique keys per session.
4. Replay protection: Nonces and sequence counters prevent reuse of captured packets.
5. Key separation: PTK (unicast) and GTK (broadcast/multicast) ensure compartmentalization of traffic security.
6. Integrity protection: Message Integrity Code (MIC) validates handshake messages, preventing tampering.
7. Dynamic key generation: Even with the same password (PSK), each session generates a different PTK.
8. Supports enterprise security: When combined with 802.1X/EAP, enables strong authentication using certificates and centralized control.

Security Cons (8 points)

1. Vulnerable to KRACK attack: Attackers can force nonce reuse and reinstall keys, enabling replay and decryption.
2. Offline dictionary attacks: In WPA2-PSK, captured handshake can be used to brute-force weak passwords.
3. No forward secrecy: If PMK is compromised, past sessions can be decrypted.
4. Management frame weakness: Traditional WPA2 does not protect management frames, enabling deauthentication attacks.
5. MIC limitations: Earlier implementations (e.g., with TKIP) had weaker MIC algorithms susceptible to forgery.
6. Replay window exploitation: Improper implementation may allow replay within acceptable sequence ranges.
7. Dependency on secure implementation: Flaws in device firmware/drivers can break handshake security.
8. GTK distribution risk: If GTK is compromised, broadcast/multicast traffic becomes exposed.

Overall, the 4-way handshake provides strong foundational security but relies heavily on proper implementation, strong passwords, and complementary protections to resist modern attacks.

Password Cracking Techniques and Solutions for Hardening

Password Cracking Techniques

1. **Brute Force Attack**
Attempts all possible combinations of characters until the correct password is found. It is time-consuming but guaranteed to succeed if no restrictions exist.
2. **Dictionary Attack**
Uses a predefined list of common passwords and words. Faster than brute force but limited to known patterns.
3. **Rainbow Table Attack**
Uses precomputed hash tables to reverse cryptographic hash functions and retrieve plaintext passwords quickly.
4. **Phishing Attack**
Tricks users into revealing passwords through fake websites, emails, or login pages.
5. **Keylogging**
Malicious software records keystrokes to capture passwords directly from user input.
6. **Credential Stuffing**
Uses previously leaked username-password combinations on multiple sites assuming password reuse.
7. **Password Spraying**
Attempts commonly used passwords (e.g., "123456", "password") across many accounts to avoid detection.
8. **Shoulder Surfing**
Observing users while they enter passwords physically or via cameras.
9. **Man-in-the-Middle (MITM) Attack**
Intercepts communication between user and server to capture credentials.
10. **Social Engineering**
Manipulates users into disclosing passwords through psychological tricks rather than technical means.

Solutions for Password Hardening

1. **Strong Password Policy**
Enforce long passwords (12+ characters) with a mix of uppercase, lowercase, numbers, and symbols.
2. **Multi-Factor Authentication (MFA)**
Adds an additional layer (OTP, biometrics, token), reducing reliance on passwords alone.
3. **Account Lockout Mechanism**
Temporarily locks accounts after multiple failed attempts to prevent brute force attacks.
4. **Salting and Hashing**
Store passwords using strong hashing algorithms (e.g., bcrypt, Argon2) with unique salts to prevent rainbow table attacks.

5. **Password Complexity Enforcement**
Prevent use of common or previously breached passwords.
6. **Regular Password Updates**
Encourage periodic password changes, especially after suspected compromise.
7. **Secure Transmission (HTTPS)**
Encrypt credentials during transmission to prevent interception.
8. **User Awareness Training**
Educate users about phishing, social engineering, and safe password practices.
9. **Use of Password Managers**
Helps generate and store complex passwords securely without reuse.
10. **Monitoring and Logging**
Detect unusual login patterns and trigger alerts for suspicious activities.

Conclusion

Password cracking techniques exploit weak passwords, human behavior, and system vulnerabilities. Effective hardening requires a combination of technical controls (hashing, MFA) and user practices (awareness, strong passwords) to build a resilient authentication system.

Traffic Acquisition Software and Its Importance in Network Forensic Investigation

Traffic acquisition software refers to specialized tools used to capture, record, and store network data packets in real time or from stored sources for analysis. These tools operate at different layers of the network and are essential for collecting digital evidence during forensic investigations.

Concept and Working

Traffic acquisition tools monitor network interfaces in promiscuous mode, allowing them to capture all packets flowing through the network segment, not just those addressed to a specific device. The captured data is stored in formats such as PCAP, which can later be analyzed to reconstruct sessions, identify anomalies, and trace malicious activities.

Examples of Traffic Acquisition Tools

Commonly used tools include Wireshark, tcpdump, NetworkMiner, and Snort. These tools differ in capabilities such as real-time capture, deep packet inspection, and intrusion detection.

Key Features of Traffic Acquisition Software

They support live packet capture, filtering (using BPF – Berkeley Packet Filter), protocol decoding, timestamping, and storage of large volumes of traffic. Advanced tools also provide session reconstruction, file extraction, and visualization of network flows.

Importance in Network Forensics

1. **Evidence Collection**
Captures raw network data that can serve as legally admissible digital evidence.
2. **Incident Reconstruction**
Helps recreate attack timelines, including entry point, lateral movement, and data exfiltration.
3. **Intrusion Detection and Analysis**
Identifies suspicious patterns such as port scans, unusual protocols, or abnormal traffic spikes.
4. **Attribution of Attacks**
Assists in tracing the source IP, communication endpoints, and attacker behavior.
5. **Malware Analysis Support**
Enables analysis of command-and-control (C2) communication and payload delivery.
6. **Protocol-Level Insight**
Provides detailed visibility into application-layer protocols like HTTP, DNS, FTP, aiding deep investigation.
7. **Verification and Correlation**
Allows correlation with logs from firewalls, IDS/IPS, and SIEM systems for comprehensive analysis.
8. **Real-Time Monitoring**
Supports proactive detection and immediate response to ongoing attacks.

Challenges and Limitations

High data volume requires significant storage and processing power. Encrypted traffic (e.g., HTTPS) limits visibility into payload content. Legal and privacy considerations must be followed during capture and analysis.

Conclusion

Traffic acquisition software is a foundational component of network forensics, enabling accurate evidence collection, detailed analysis, and effective incident response. Its proper use enhances the ability to detect, investigate, and mitigate cyber threats efficiently.

Wireshark

Introduction

Wireshark is a widely used open-source network protocol analyzer used for capturing, inspecting, and analyzing network traffic at a very granular level. It is a core tool in network forensics, troubleshooting, and security analysis because it provides packet-level visibility of communications across networks.

Working Principle

Wireshark captures packets from network interfaces operating in promiscuous or monitor mode. Each packet is dissected into layers (as per OSI/TCP-IP model), allowing analysts to inspect headers, payloads, and protocol-specific fields. Captured data is stored in PCAP/PCAPNG format for offline analysis.

Types of Capture in Wireshark

1. **Live Capture**
Captures real-time traffic from network interfaces such as Ethernet, Wi-Fi, or virtual adapters.
2. **Remote Capture**
Captures packets from remote systems using protocols like RPCAP.
3. **Offline Capture Analysis**
Opens and analyzes previously saved PCAP files without needing live traffic.
4. **Monitor Mode Capture (Wireless)**
Captures raw 802.11 frames including management and control frames (useful in Wi-Fi security analysis).

Capture Features

- **Promiscuous Mode:** Captures all packets on the network segment.
- **Monitor Mode:** Captures raw wireless frames (not just data packets).
- **Packet Buffering:** Temporary storage before writing to disk.
- **Ring Buffer Capture:** Automatically rotates files to manage large captures.
- **Name Resolution:** Converts IP/MAC into human-readable names.
- **Time Stamping:** Precise timing of packets for sequence and delay analysis.
- **Multi-interface Capture:** Capture from multiple interfaces simultaneously.
- **Packet Coloring Rules:** Visual differentiation of protocols/traffic types.

Types of Filters in Wireshark

1. Capture Filters (applied before capture)

Based on Berkeley Packet Filter (BPF) syntax; reduces data collected.

Examples:

- `host 192.168.1.1` → capture traffic to/from specific IP
- `port 80` → capture HTTP traffic
- `tcp` → capture only TCP packets
- `net 192.168.1.0/24` → capture traffic from subnet
- `tcp port 443 and host 10.0.0.5`

2. Display Filters (applied after capture)

More powerful and protocol-aware; used for analysis.

Examples:

- `ip.addr == 192.168.1.1`
- `tcp.port == 80`
- `http` → show only HTTP packets
- `dns` → filter DNS queries/responses
- `tcp.flags.syn == 1 && tcp.flags.ack == 0` → detect SYN packets (possible scan)
- `frame contains "password"` → search keyword in packets
- `ip.src == 192.168.1.5 && ip.dst == 8.8.8.8`

Protocol Analysis Capability

Wireshark supports deep inspection of hundreds of protocols including TCP, UDP, HTTP, DNS, FTP, SSL/TLS, ARP, ICMP, and more. It reconstructs sessions, follows TCP streams, and extracts transferred files.

Important Features for Forensics and Security

- **Follow TCP Stream:** Reconstruct entire communication session
- **Protocol Hierarchy Statistics:** Shows distribution of protocols
- **IO Graphs:** Visualizes traffic patterns over time
- **Expert Information:** Highlights anomalies and errors
- **Decryption Support:** Can decrypt TLS (with keys), WPA/WPA2 traffic (with handshake + key)
- **Packet Reassembly:** Combines fragmented packets
- **Export Objects:** Extract files from HTTP, SMB, FTP traffic

Advantages

- Deep packet inspection and protocol decoding
- Open-source and widely supported
- Strong filtering and visualization capabilities
- Essential for troubleshooting and forensic investigations

Limitations

- Cannot capture traffic outside its network segment without proper setup
- Encrypted traffic limits visibility
- High traffic environments may lead to packet drops
- Requires expertise to interpret data correctly

Conclusion

Wireshark is a powerful and essential tool for network analysis and digital forensics. Its strength lies in detailed packet inspection, flexible filtering, and strong analytical capabilities, making it indispensable for cybersecurity professionals in detecting, analyzing, and investigating network-based attacks.

SNMP Service Enumeration

SNMP (Simple Network Management Protocol) is a network management protocol used to monitor and manage devices such as routers, switches, servers, printers, and IoT systems. SNMP service enumeration is the process of extracting information from SNMP-enabled devices to identify system details, configurations, and potential vulnerabilities. It is commonly used in both penetration testing and network forensic analysis.

Working of SNMP

SNMP operates on UDP port 161 (queries) and port 162 (traps). It follows a manager-agent model where the SNMP manager queries the SNMP agent running on a device. Information is

stored in a structured database called MIB (Management Information Base), where each parameter is identified using an OID (Object Identifier).

Concept of Enumeration

Enumeration refers to actively querying SNMP services to gather detailed information such as system name, uptime, running processes, network interfaces, routing tables, and user accounts. This is especially effective when default or weak community strings are used.

SNMP Versions and Security Context

SNMPv1 and SNMPv2c use community strings (like passwords) such as “public” (read-only) and “private” (read-write), which are transmitted in plaintext. SNMPv3 improves security by introducing authentication (MD5/SHA) and encryption (DES/AES).

Enumeration Techniques

1. **Community String Guessing**
Attempting default or brute-forced community strings to gain access.
2. **SNMP Walk**
Retrieves a large portion of the MIB tree to gather extensive device information.
3. **SNMP Get / GetNext**
Queries specific OIDs or sequential values.
4. **Brute Force Enumeration**
Uses wordlists to discover valid community strings.
5. **Automated Scanning Tools**
Tools like snmpwalk, snmp-check, Nmap (with SNMP scripts), and Metasploit are commonly used.

Important Information Gathered

- System details (hostname, OS, uptime)
- Network interfaces and IP addresses
- Routing tables
- ARP tables
- Running services and processes
- User accounts
- Installed software
- Device location and contact details

Security Risks of SNMP Enumeration

- Exposure of sensitive network information
- Unauthorized configuration changes (if write access is enabled)
- Network mapping for further attacks
- Credential leakage via weak/default community strings

Countermeasures / Hardening

- Disable SNMP if not required

- Use SNMPv3 instead of v1/v2c
- Change default community strings
- Restrict SNMP access using ACLs (IP-based filtering)
- Use strong authentication and encryption
- Monitor SNMP traffic for suspicious activity
- Limit MIB access to only required OIDs

Conclusion

SNMP enumeration is a powerful technique for gathering detailed network intelligence. While useful for administrators, improper configuration (especially in SNMPv1/v2c) can expose critical information to attackers. Securing SNMP services is essential to prevent reconnaissance and potential exploitation.

Digital Signature and Its Working

Introduction

A digital signature is a cryptographic mechanism used to verify the authenticity, integrity, and non-repudiation of digital data such as messages, documents, or transactions. It ensures that the data has not been altered and that it originates from a verified sender.

Concept

Digital signatures are based on asymmetric cryptography (public key cryptography), where each user has a pair of keys: a private key (kept secret) and a public key (shared openly). The private key is used to create the signature, while the public key is used to verify it.

Core Security Properties

- **Authentication:** Confirms the identity of the sender
- **Integrity:** Ensures the message has not been modified
- **Non-repudiation:** Sender cannot deny signing the message

Working of Digital Signature (Step-by-Step)

1. **Message Creation**
The sender prepares the original message or document.
2. **Hash Generation**
A hash function (e.g., SHA-256) is applied to the message to produce a fixed-length message digest. This digest uniquely represents the data.
3. **Signature Generation**
The sender encrypts the hash using their private key (e.g., via RSA). This encrypted hash becomes the digital signature.
4. **Transmission**
The sender sends both the original message and the digital signature to the receiver.
5. **Hash Recalculation (Receiver Side)**
The receiver computes the hash of the received message using the same hash algorithm.

6. Signature Verification

The receiver decrypts the digital signature using the sender's public key to obtain the original hash.

7. Comparison

If both hashes match, the message is authentic and unaltered. If not, integrity is compromised.

Mathematical View (Simplified)

Signature = Encrypt(Hash(Message), Private Key)

Verification = Decrypt(Signature, Public Key) and compare with Hash(Message)

Role of Digital Certificates

To ensure that the public key truly belongs to the sender, digital signatures are often combined with certificates issued by a Certificate Authority (CA) under Public Key Infrastructure (PKI).

Applications

- Secure email (S/MIME)
- Software code signing
- Online transactions and e-commerce
- Blockchain and cryptocurrencies
- Legal and government documents (e-signatures)

Advantages

- Strong security with cryptographic assurance
- Prevents forgery and tampering
- Legally accepted in many jurisdictions
- Enables secure digital communication

Limitations

- Requires proper key management
- Private key compromise breaks security
- Computational overhead compared to simple authentication
- Dependence on trusted Certificate Authorities

Conclusion

Digital signatures are a fundamental component of modern cybersecurity, ensuring trust, integrity, and accountability in digital communications. Their effectiveness depends on secure key management and proper implementation within a PKI framework.

Basis	TCP (Transmission Control Protocol)	UDP (User Datagram Protocol)
Type of Service	Connection-oriented	Connectionless

Reliability	Reliable (guarantees delivery)	Unreliable (no guarantee)
Data Delivery	Ordered and sequential	Unordered
Error Checking	Yes (error detection + recovery)	Only error detection (no recovery)
Acknowledgment	Uses ACKs	No acknowledgment
Retransmission	Yes, lost packets retransmitted	No retransmission
Flow Control	Yes (windowing mechanism)	No flow control
Congestion Control	Yes (e.g., slow start, congestion avoidance)	No congestion control
Speed	Slower due to overhead	Faster due to minimal overhead
Header Size	Larger (20–60 bytes)	Smaller (8 bytes)
Communication Mode	Stream-oriented	Message-oriented (datagram-based)
Setup	Requires 3-way handshake	No connection setup
Overhead	High	Low
Use Cases	Web browsing (HTTP/HTTPS), email, file transfer (FTP)	Streaming, VoIP, online gaming, DNS
Data Integrity	High (ensures complete and correct delivery)	Low (packets may be lost or duplicated)